

CertiGhost Exploit Allows Low-Privileged Active Directory Users to Impersonate a Domain Controller

 thecybersecguru.com/news/certighost-cve-2026-54121-ad-cs-domain-controller-impersonation

The CyberSec Guru

July 26, 2026



A newly disclosed vulnerability in **Active Directory Certificate Services (AD CS)** demonstrates how a standard domain user can escalate privileges to complete Active Directory compromise by abusing a flaw in Microsoft's certificate enrollment process. The vulnerability, tracked as **CVE-2026-54121** and nicknamed **Certighost**, was patched by Microsoft on **July 14, 2026**, but public exploitation became significantly more practical after security researchers **H0j3n** and **Aniq Fakhru** released a fully working proof-of-concept on **July 24**.

Unlike many Active Directory privilege escalation techniques that rely on misconfigured certificate templates or delegated administrative permissions, Certighost targets the logic inside the Enterprise Certification Authority itself. Under specific deployment conditions, the CA can be convinced to issue a certificate containing the identity of a legitimate Domain Controller even though the request originated from an attacker-controlled machine. Once that certificate has been issued, it can be used with Kerberos PKINIT authentication to obtain Domain Controller credentials, enabling DCSync attacks that expose the **krbtgt** account and effectively hand over control of the domain.

Microsoft assigned the vulnerability a **CVSS score of 8.8** and classified it as an **improper authorization** issue. Exploitation requires a valid domain account and network connectivity, but it does not require administrator privileges or any user interaction. As of

July 24, there were no confirmed reports of active exploitation in the wild, and the vulnerability was not listed in CISA's Known Exploited Vulnerabilities catalog. However, the availability of a public exploit substantially lowers the barrier for attackers targeting vulnerable AD CS deployments.

Understanding the Role of AD CS

To understand why this vulnerability is significant, it helps to understand how Active Directory Certificate Services operates within a Windows domain.

AD CS provides the Public Key Infrastructure (PKI) used throughout Active Directory. Instead of relying solely on passwords, Windows can authenticate users, computers, smart cards, VPN clients, and numerous enterprise services using X.509 certificates issued by an Enterprise Certification Authority.

When a certificate is issued, the CA effectively signs a statement asserting that a particular public key belongs to a specific Active Directory identity. Windows components trust this signature because the certificate originates from the Enterprise CA.

Those certificates are used for numerous security-sensitive operations, including TLS authentication, code signing, smart card logons, device authentication, and **Public Key Cryptography for Initial Authentication in Kerberos (PKINIT)**. During PKINIT, a client presents its certificate to the Key Distribution Center (KDC), which validates the certificate and maps its identity information to an Active Directory object before issuing Kerberos tickets.

The security of the entire process therefore depends on one critical assumption: the Certification Authority must accurately determine **who** is requesting the certificate.

Certifhost breaks this assumption.

Where the Vulnerability Exists

The flaw resides within an AD CS enrollment mechanism known as a **chase**.



Stay Ahead of Cyber Threats

Get the latest cybersecurity news, critical vulnerabilities, threat intelligence, tutorials, and exclusive giveaways delivered straight to your inbox. No spam. Unsubscribe anytime.

[Subscribe to the Newsletter →](#)

During certain enrollment scenarios, the Certification Authority may need additional directory information before issuing a certificate. Rather than relying solely on the

information already available locally, the CA performs a secondary lookup to retrieve attributes associated with the requested identity.

This lookup is controlled by two enrollment request attributes:

- **cdc** specifies which Domain Controller the CA should contact.
- **rmd** specifies which directory object should be resolved.

The vulnerable implementation trusted the hostname supplied through the **cdc** attribute without verifying that the specified server was actually a legitimate Domain Controller.

```
—$ certipy-ad req -u normaluser@abc.local -p 'Passw0rd123!!' -dc-ip 192.168.8.128 -target WCA01.abc.local \
    -ca abc-WCA01-CA -template User
Certipy v5.0.4 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Request ID is 721
[*] Successfully requested certificate
[*] Got certificate with UPN 'normaluser@abc.local'
[*] Certificate object SID is 'S-1-5-21-4077585377-2659985027-3163688340-1116'
[*] Saving certificate and private key to 'normaluser.pfx'
[*] Wrote certificate and private key to 'normaluser.pfx'
```

Authenticating certificate using Certipy

Instead of first validating the destination, the CA attempted to communicate with the supplied host using SMB and LDAP.

That design decision created the opportunity for attackers to position themselves directly inside the enrollment workflow.

Exploiting the Trust Relationship

An attacker with nothing more than a normal domain account can prepare a machine under their control to impersonate the services that the Certification Authority expects to communicate with.

The proof-of-concept launches rogue implementations of SMB, LDAP, and Local Security Authority (LSA) services. When the Certification Authority connects to the attacker-controlled host specified by the **cdc** attribute, those services participate in the enrollment process while relaying portions of the authentication flow to the legitimate Domain Controller using Netlogon.

Rather than inventing an entirely fake identity, the attacker returns carefully chosen information belonging to the real Domain Controller, including its **objectSid** and **dNSHostName**.

At the same time, the attacker authenticates using a machine account they legitimately control.

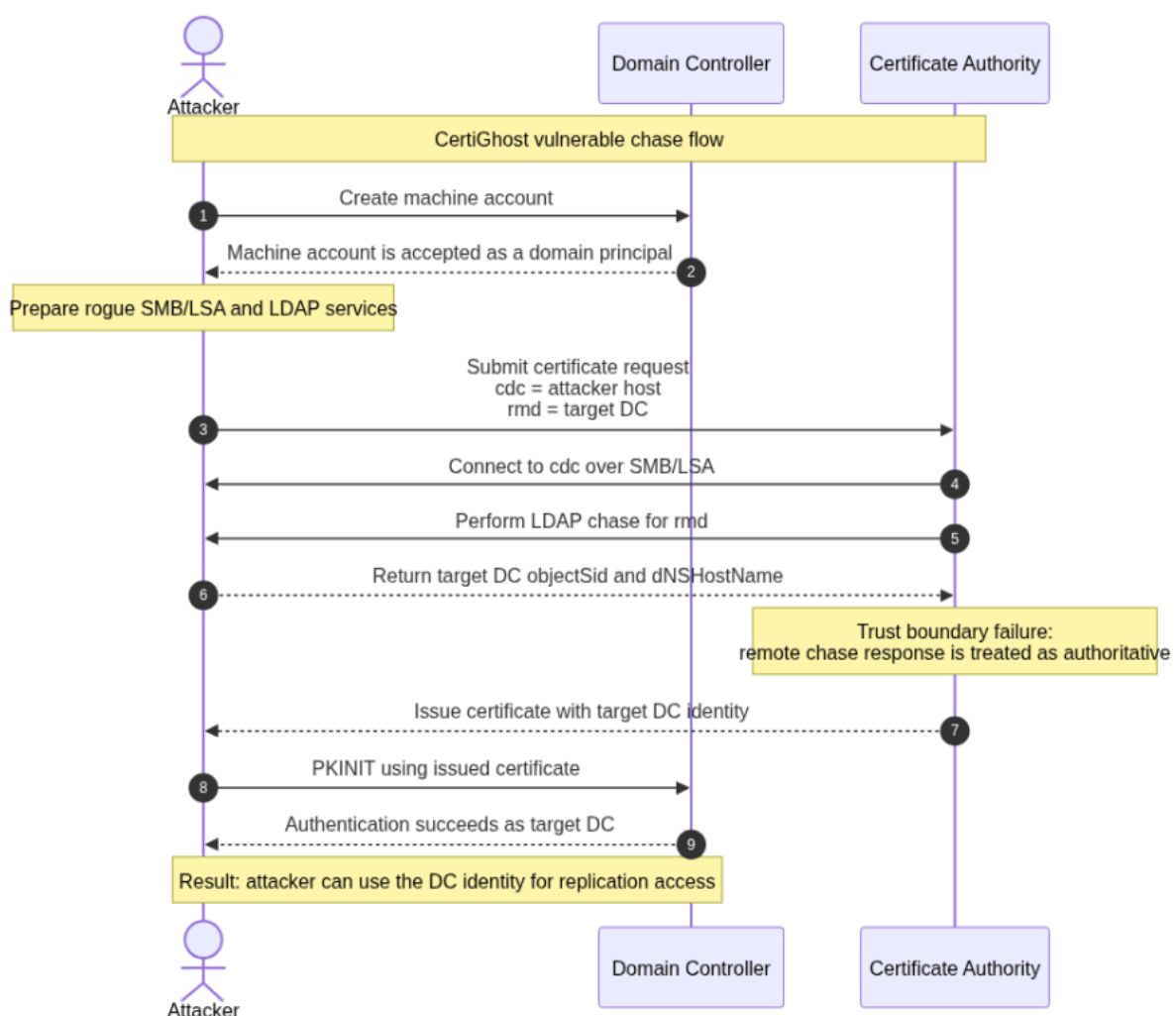
This distinction is important.

The attack does not bypass every validation step performed by the Certification Authority. Instead, it combines legitimate authentication with manipulated directory information so that the CA incorrectly concludes it is communicating with the actual Domain Controller.

Because the vulnerable code never verified that the supplied **cdc** server genuinely represented the Domain Controller whose identity information was being returned, the CA accepted the response and continued processing the enrollment request.

Ultimately, it signed a certificate containing the identity of the real Domain Controller while the request itself originated from infrastructure fully controlled by the attacker.

The Certification Authority therefore became an unwitting participant in issuing a highly privileged certificate.



How CertiGhost Works

Why MachineAccountQuota Matters

One of the reasons the exploit is practical in default Active Directory environments is the **ms-DS-MachineAccountQuota** attribute.

By default, most Active Directory domains allow authenticated users to create up to **ten computer accounts**.

This behavior exists to simplify workstation provisioning without requiring administrators to manually pre-create every computer object.

The exploit takes advantage of this default configuration by creating a machine account that the attacker legitimately owns. If an attacker already controls a machine account, the proof-of-concept can simply reuse it instead of creating a new one.

The machine account provides the valid Active Directory identity required during the enrollment process while the rogue services manipulate the directory information presented to the Certification Authority.

No domain administrator privileges are necessary.

From Certificate Issuance to Domain Compromise

Receiving the fraudulent certificate is not the final objective.

Instead, the certificate becomes the authentication mechanism used to impersonate the Domain Controller.

The proof-of-concept performs **PKINIT** authentication using the newly issued certificate, allowing the attacker to obtain Kerberos credentials representing the targeted Domain Controller.

Once operating as a Domain Controller, the attacker inherits one of the most sensitive privileges within Active Directory: directory replication.

That privilege enables **DCSync**, a technique that requests password data directly through the Directory Replication Service Remote Protocol rather than reading the NTDS database from disk.

Among the secrets obtainable through DCSync is the password hash for the **krbtgt** account.

The krbtgt account is the cryptographic foundation of Kerberos within an Active Directory domain. It signs Ticket Granting Tickets (TGTs), making it one of the highest-value secrets in the environment.

If an attacker obtains the krbtgt secret, they can forge Kerberos tickets that are trusted by every Domain Controller in the forest until the account password is reset appropriately.

For this reason, compromise of krbtgt is widely considered equivalent to full Active Directory compromise.

What the Public Exploit Automates

The [published proof-of-concept](#) removes much of the complexity previously associated with abusing the vulnerability.

It can automatically create a new computer account when the default MachineAccountQuota permits it or reuse an existing attacker-controlled computer account.

The exploit then starts SMB and LDAP listeners, relays the Certification Authority's authentication requests through Netlogon to the legitimate Domain Controller, submits the crafted enrollment request containing the manipulated **cdc** and **rmd** values, and finally exports both the issued certificate in **PFX** format and a Kerberos credential cache suitable for immediate use.

While the attack chain still depends on environmental prerequisites, the automation significantly reduces the technical effort required to execute the attack in vulnerable environments.

Microsoft's Fix

Microsoft addressed the vulnerability in its July 2026 security updates by strengthening validation inside the certificate enrollment workflow.

Researchers analyzing the patched binaries identified a new validation routine named **CRequestInstance::_ValidateChaseTargetIsDC** within **certpdef.dll**.

Before following a chase request, the updated code now validates that the supplied target genuinely represents a Domain Controller.

Among other checks, the validation rejects IP address literals, oversized hostnames, malformed input, and LDAP metacharacters that could interfere with directory queries.

The Certification Authority then queries Active Directory to confirm that the target corresponds to exactly one computer object whose DNS name matches the supplied hostname and whose **userAccountControl** attribute contains the **SERVER_TRUST_ACCOUNT (0x2000 / 8192)** flag identifying a Domain Controller.

Microsoft also introduced an additional SID comparison step designed to prevent object substitution attacks during the enrollment process.

Collectively, these validations prevent attackers from redirecting the Certification Authority toward arbitrary systems while claiming the identity of a legitimate Domain Controller.

Temporary Mitigation

Organizations unable to deploy Microsoft's July security updates immediately can disable the vulnerable chase behavior by clearing the **EDITF_ENABLECHASECLIENTDC** policy flag using:

The researchers emphasize that this is a temporary mitigation rather than a permanent solution. Disabling the chase mechanism may interrupt legitimate certificate enrollment workflows that rely on this functionality, so changes should be validated in a staging environment before deployment. Applying Microsoft's security updates remains the recommended long-term remediation.

Affected Systems

Microsoft's advisory and the National Vulnerability Database identify multiple supported Windows Server releases as affected prior to the July 2026 updates, including Windows Server 2012, 2012 R2, 2016, 2019, 2022, and 2025, along with their Server Core installations where applicable. The NVD also lists Windows 10 versions 1607 and 1809. Exploitation additionally requires an Enterprise AD CS deployment that follows the vulnerable chase path and a certificate enrollment workflow capable of reaching attacker-controlled SMB and LDAP services.

Why Certighost Matters

Active Directory Certificate Services has become one of the most frequently targeted components in enterprise Windows environments because it occupies a unique position within the trust architecture of the domain. Unlike vulnerabilities that exploit memory corruption or remote code execution, Certighost demonstrates how flaws in identity validation alone can produce complete domain compromise.

The vulnerability does not depend on exploiting Kerberos, bypassing cryptography, or breaking certificate signatures. Instead, it abuses the Certification Authority's trust decisions during enrollment. Once the CA incorrectly associates a certificate with a Domain Controller, every downstream security mechanism behaves exactly as designed, trusting the issued certificate because it originated from a legitimate Enterprise CA.

That makes vulnerabilities in certificate issuance particularly dangerous. The cryptography remains sound, but the identity bound to the certificate is wrong.

Organizations running AD CS should treat CVE-2026-54121 as a high-priority patch, especially now that a public proof-of-concept exists. Even though no confirmed in-the-wild exploitation has been reported at the time of writing, publicly available exploitation code substantially increases the likelihood of opportunistic attacks against unpatched Enterprise Certification Authorities.